

MODULE 40 · EXAM STRATEGY - ALL DOMAINS

Practice exam 1 of 4

20 questions, weighted to the real domain distribution. Nine seconds per question – pause for longer if you need it.

QUESTIONS 20 PASS MARK 15 of 20 HOLD 9 seconds

A security team receives an alert that CloudTrail logging was stopped in a member account. Investigation shows an IAM role called deployment-automation called StopLogging on the organization trail's local copy. The organization trail itself continued logging.

The team wants to be certain no principal in any member account can stop, delete or modify organization trail logging, and to be alerted if one tries.

What should the team implement?

- ☐ A An IAM policy on every role denying cloudtrail:StopLogging
- ☐ B An SCP denying cloudtrail:StopLogging, DeleteTrail and UpdateTrail, plus an EventBridge rule on those API calls
- ☐ C CloudTrail log file integrity validation on the organization trail
- ☐ D A Config rule checking that CloudTrail is enabled, with automatic remediation

◆ PAUSE AND DECIDE

What should the team implement?

- A

 An IAM policy on every role
Requires attaching to every role that exists and every one created later. An SCP caps the whole account without enumeration.
- C

 Log file integrity validation
Detects tampering with delivered log files. It does nothing about someone stopping the logging in the first place.
- B

 SCP denying the three actions, plus an EventBridge rule
Correct. The SCP gives certainty across every principal in every member account; the EventBridge rule gives the alerting the requirement also asks for.
- D

 Config rule with remediation
Detective and corrective - there is a gap between stopping and re-enabling, and the requirement says be certain nobody can.

DOMAIN 1

Two requirements – certainty and alerting – so the answer needs two mechanisms. B is the only option offering both.

An organisation enables GuardDuty through Organizations with auto-enable for new accounts. Six months later, a compromised instance in ap-northeast-3 mined cryptocurrency for eleven days before a finance review noticed the cost. GuardDuty produced no findings for that account at any point during the eleven days.

What is the MOST likely explanation?

- ☐ A GuardDuty does not detect cryptomining without Runtime Monitoring enabled
- ☐ B The finding severity was below the threshold configured for notifications
- ☐ C The account joined the organisation before auto-enable was configured
- ☐ D GuardDuty is Regional and was not enabled in ap-northeast-3

◆ PAUSE AND DECIDE

What is the MOST likely explanation?

- A

 Needs Runtime Monitoring for cryptomining
GuardDuty detects cryptocurrency activity from VPC Flow Logs and DNS logs alone. Runtime Monitoring adds process-level detail, not the basic finding.
- B

 Below the notification threshold
Would explain no alert, not no findings. The question says GuardDuty produced no findings at all.
- C

 Joined before auto-enable
Plausible, and it would leave the account uncovered in every Region rather than in one - and the organisation would likely have noticed.
- D

 GuardDuty is Regional and was not enabled there
Correct. Enabling GuardDuty organisation-wide does not enable it in every Region. An unused Region is exactly where this goes unnoticed.

DOMAIN 1

'No findings' from a Region nobody uses usually means nothing is watching it, not that nothing happened.

A company must correlate security findings from AWS, a third-party endpoint agent, and its own network sensors into one queryable store, using a schema that all three can be normalised into without bespoke parsers for each.

The company already uses Security Hub CSPM for AWS posture scoring and wants to keep it.

What should the company use for the correlation store?

- ☐ A Amazon Security Lake, normalising sources into OCSF
- ☐ B CloudTrail Lake with an event data store per source
- ☐ C Security Hub CSPM, ingesting third-party findings as ASFF
- ☐ D Amazon Detective with third-party data sources added

◆ PAUSE AND DECIDE

What should the company use for the correlation store?

A Security Lake with OCSF

Correct. Security Lake normalises AWS and third-party sources into the Open Cybersecurity Schema Framework, which is exactly the 'one schema, no bespoke parsers' requirement.

C Security Hub CSPM with ASFF

The strongest distractor – ASFF is a real normalising format for findings. Security Hub CSPM scores posture rather than serving as a queryable data lake, and the company is keeping it anyway.

B CloudTrail Lake per source

Built around AWS API activity and its own event schema. It is not a general normalisation layer for endpoint agents and network sensors.

D Detective with third-party sources

Detective builds behaviour graphs from AWS telemetry. It is an investigation tool, not a store you normalise arbitrary sources into.

DOMAIN 1

'One schema all three normalise into' names OCSF, and OCSF names Security Lake.

An analyst confirms that an EC2 instance in a production VPC is communicating with a known command-and-control server. The instance runs a stateless component behind a load balancer. Forensic evidence must be preserved.

The security team asks what to do FIRST.

What should be done FIRST?

- ☐ A Take an EBS snapshot and copy it to the forensics account
- ☐ B Terminate the instance to stop the outbound communication
- ☐ C Replace the instance's security group with one permitting no traffic, and deregister it from the load balancer
- ☐ D Capture the memory of the running instance with SSM

◆ PAUSE AND DECIDE

What should be done FIRST?

- A

 Snapshot and copy to forensics
A correct action that comes second. The attacker retains control while you snapshot, and can act during it.
- B

 Terminate the instance
Stops the communication and destroys instance store, memory and the attacker's live state. Eradication before evidence.
- C

 Isolating security group, deregister from the load balancer
Correct. Isolation stops the harm immediately while preserving the instance, its volumes and its memory for the steps that follow.
- D

 Capture memory first
Valuable evidence, and it happens while the attacker still has an open channel. Isolate, then capture.

DOMAIN 2

FIRST means the immediate next action. Isolate, capture, eradicate, recover – in that order.

Long-lived access keys for an IAM user were published in a public repository. The keys have been deleted. CloudTrail shows the keys were used two hours before deletion to call `sts:GetSessionToken`, and the resulting temporary credentials are still being used. The team needs those temporary credentials to stop working immediately.

What should the team do?

- ☐ A Attach a policy to the user denying all actions when `aws:TokenIssueTime` is earlier than now
- ☐ B Delete the IAM user, which invalidates all sessions derived from it
- ☐ C Rotate the user's password and enforce MFA on the account
- ☐ D Wait for the session to expire; temporary credentials cannot be revoked

◆ PAUSE AND DECIDE

What should the team do?

- A

 Deny with a DateLessThan on aws:TokenIssueTime
Correct. This is the AWSRevokeOlderSessions pattern - it denies every session issued before the cut-off while leaving new ones working.
- B

 Delete the IAM user
The most common wrong instinct. Deleting the identity does not invalidate credentials already issued from it; they remain valid until expiry.
- C

 Rotate password and enforce MFA
Good hygiene for the future, and it has no effect on a session already issued.
- D

 Wait for expiry
Half true and defeatist. There is no revoke API, and a deny on TokenIssueTime achieves the same outcome immediately.

DOMAIN 2

You cannot revoke a temporary credential. You can deny every session issued before a moment in time, which is equivalent.

A forensics team in a dedicated account must analyse an EBS volume from a compromised instance in a production account. The production volume is encrypted with the default AWS managed EBS key.

The team shares the snapshot with the forensics account, which cannot use it.

What is required?

- ☐ A Grant the forensics account kms:Decrypt on the AWS managed key
- ☐ B Copy the snapshot without encryption, then share it
- ☐ C Add the forensics account to the snapshot's createVolumePermission and retry
- ☐ D Copy the snapshot, re-encrypting with a customer managed key, and share that key with the forensics account

◆ PAUSE AND DECIDE

What is required?

- A

 Grant kms:Decrypt on the AWS managed key
You cannot modify the key policy of an AWS managed key, so nobody can be granted use of it. That is precisely why the share fails.
- C

 Add createVolumePermission
The sharing mechanism is already what was attempted. The block is the key, not the permission.
- B

 Copy without encryption
You cannot remove encryption from an encrypted snapshot. And decrypting evidence to move it would be a poor forensic choice even if you could.
- D

 Copy re-encrypting under a CMK, and share the key
Correct. A snapshot copy can change the key. A customer managed key has a policy you control, so the forensics account can be granted use of it.

DOMAIN 2

Nothing encrypted with an AWS managed key can be shared. Re-encrypt during the copy, under a key whose policy you own.

A login endpoint behind CloudFront and AWS WAF is being attacked by credential stuffing from roughly 40,000 residential IP addresses, each making two or three requests per hour. A per-IP rate-based rule at the lowest threshold has no effect.

The traffic all originates from a small number of automation toolkits.

What should be configured?

- ☐ A A geographic match rule blocking the countries the addresses resolve to
- ☐ B An IP set containing the 40,000 addresses, refreshed hourly
- ☐ C A rate-based rule aggregating on the JA4 fingerprint rather than source IP
- ☐ D Shield Advanced automatic application layer DDoS mitigation

◆ PAUSE AND DECIDE

What should be configured?

- A

 Geographic match rule
Residential addresses in the same countries as your legitimate users. This blocks customers and the attacker moves.
- B

 IP set of 40,000 addresses
Chasing addresses that rotate. By the time the set refreshes, the attack has moved – and the set has real limits.
- C

 Rate-based rule aggregating on JA4
Correct. The addresses rotate but the TLS client fingerprint does not, so aggregating on JA4 collapses 40,000 sources into a few toolkits.
- D

 Shield Advanced automatic L7 mitigation
Retiring on 1 January 2027, and built for volumetric DDoS. Two or three requests per hour per address is not a volume signal.

DOMAIN 3

'A small number of automation toolkits' is the clue. The thing that does not rotate is the fingerprint.

Malware on an instance in a private subnet contacts its command-and-control infrastructure by connecting directly to a hardcoded IP address on port 443. The company has Route 53 Resolver DNS Firewall configured with a comprehensive blocked-domain list. The connections succeed and DNS Firewall logs show nothing.

Why, and what should the company add?

- ☐ A The domain list needs the Advanced tier to detect the domain; upgrade it
- ☐ B No DNS lookup occurs, so DNS Firewall never sees it; add AWS Network Firewall
- ☐ C DNS Firewall only inspects UDP port 53; enable TCP inspection
- ☐ D The instance uses a custom resolver; force it to the VPC resolver with a DHCP option set

◆ PAUSE AND DECIDE

Why, and what should the company add?

- A

 Upgrade to the Advanced tier
Advanced detects tunneling and algorithmically generated domains. It still only sees DNS queries, and there is no query here.
- C

 Enable TCP inspection
Invented setting, and it would not matter. The traffic is HTTPS to an IP address, not DNS over TCP.
- B

 No lookup occurs; add Network Firewall
Correct. DNS Firewall filters names. A hardcoded IP makes no query at all, so only a firewall inspecting packets can stop it.
- D

 Force the VPC resolver
A real and worthwhile control against resolver bypass. It solves a different problem - here there is no resolution to redirect.

DOMAIN 3

The empty log is the evidence. Nothing was queried, so nothing was filtered.

A regulated workload in a private subnet must reach only two S3 buckets owned by the company, and nothing else in S3. It must not reach the internet. The company already routes S3 traffic through a gateway VPC endpoint.

A reviewer notes that the current design allows the workload to write to any S3 bucket in any account.

What should be added?

- ☐ A A security group rule allowing only the S3 prefix list
- ☐ B A NACL denying outbound traffic to all addresses except S3
- ☐ C An SCP denying s3:* except on the two bucket ARNs
- ☐ D A VPC endpoint policy allowing only the two bucket ARNs

◆ PAUSE AND DECIDE

What should be added?

- A

 Security group with the S3 prefix list
Controls reaching S3 as a service. It cannot distinguish one bucket from another – the prefix list is addresses, not ARNs.
- B

 NACL denying all but S3
Same layer problem as A, at subnet level. Packets to S3 look identical regardless of which bucket they target.
- C

 An SCP scoped to two buckets
Would work and caps every principal in the account, not just this workload – broader than asked, and it does not use the endpoint the design already has.
- D

 An endpoint policy allowing only the two buckets
Correct. The endpoint policy is a resource policy on the endpoint itself, evaluated on every request passing through it, and it understands bucket ARNs.

DOMAIN 3

Network controls cannot see a bucket name. Anything scoped to a specific bucket has to be a policy that reads ARNs.

A customer support application built on Amazon Bedrock lets users ask free-text questions. Testing shows that a user can instruct the model to ignore its instructions and reveal the contents of its system prompt, which contains internal escalation procedures. The team asks for the MOST effective mitigation.

What is the MOST effective mitigation?

- ☐ A Move sensitive procedures out of the system prompt, and add a Bedrock guardrail as a second layer
- ☐ B Add a guardrail denied topic for 'system prompt' and related phrasings
- ☐ C Enable Bedrock model invocation logging so prompt injection attempts are detected
- ☐ D Switch to a larger foundation model that resists instruction override

◆ PAUSE AND DECIDE

What is the MOST effective mitigation?

- A** Remove the secrets from the prompt, then add a guardrail
Correct. AWS states there is no reliable prevention for prompt injection, so the durable fix is that leaking the system prompt stops mattering. The guardrail is a layer, not the solution.
- B** A denied topic for 'system prompt'
Filters the phrasings you thought of. Prompt injection is open-ended, and the sensitive content is still sitting there to be extracted another way.
- C** Invocation logging
Detective, and it records the attempt after the leak. Note also that guardrail-blocked content still appears in invocation logs in plain text.
- D** A larger model
No model is immune to instruction override, and AWS makes no such claim. This trades cost for a false sense of safety.

DOMAIN 3

LLM07 is system prompt leakage. The mitigation is not to defend the prompt better – it is to keep nothing in it worth leaking.

Account A contains a role that a Lambda function in Account B must assume. The role's trust policy allows Account B's root. Account B's Lambda execution role has an identity policy allowing sts:AssumeRole on the role ARN.

The AssumeRole call is denied. There are no SCPs, RCPs, permissions boundaries or session policies anywhere in either account.

What is the MOST likely cause?

- ☐ A A role in Account A cannot be assumed by a Lambda execution role
- ☐ B The trust policy must name the execution role ARN, not the account root
- ☐ C The trust policy is missing sts:AssumeRole in its Action element
- ☐ D Cross-account role assumption requires an external ID

◆ PAUSE AND DECIDE

What is the MOST likely cause?

- A

 Lambda roles cannot assume cross-account roles
They can. An execution role is an ordinary IAM role and assumes cross-account roles routinely.
- B

 Trust must name the execution role, not the root
Naming the account root delegates to Account B's IAM, which is a valid and common pattern. Narrower is better practice, not a requirement.
- C

 Missing sts:AssumeRole in the trust policy Action
Correct. Cross-account needs both sides to allow. A trust policy without sts:AssumeRole in its Action grants nothing, whatever its Principal says.
- D

 External ID is required
A confused-deputy defence for third-party access, and it is optional. Its absence does not cause a denial.

DOMAIN 4

Cross-account is the one case where both grants are required. Check both elements of the trust policy, not just the Principal.

A platform team lets application teams create IAM roles by granting `iam:CreateRole` and `iam:PutRolePolicy` with a condition requiring `iam:PermissionsBoundary` to equal the platform boundary ARN.

A penetration test shows an application team creating a bounded role, then immediately calling `iam>DeleteRolePermissionsBoundary`, producing an unbounded role in two API calls.

What should the platform team add?

- ☐ A An SCP denying `iam:CreateRole` in application accounts
- ☐ B A Deny on `iam>DeleteRolePermissionsBoundary` and `iam:PutRolePermissionsBoundary`, and on editing the boundary policy
- ☐ C A Config rule detecting roles without a permissions boundary, with remediation
- ☐ D A session policy on the application team's role restricting IAM actions

◆ PAUSE AND DECIDE

What should the platform team add?

- A

 SCP denying iam:CreateRole
Removes the delegation the design exists to provide, returning every role request to the platform team.
- B

 Deny removing or changing the boundary, and editing the boundary policy
Correct. Three controls are needed together: cannot create without it, cannot remove it afterwards, cannot edit the ceiling itself.
- C

 Config rule with remediation
Detective. There is a window in which an unbounded role exists and can be used, which is exactly what the penetration test exploited.
- D

 A session policy restricting IAM actions
A session policy caps a session and would have to be passed on every assumption. It is not a durable control on what a team may do.

DOMAIN 4

Ask what the delegate can do on their second API call, not just their first.

A company uses IAM Identity Center with Okta as its identity source, connected by SAML with SCIM provisioning. To satisfy an audit finding, the security team enables MFA in IAM Identity Center and sets it to 'always-on'.

Three months later, an audit sample of sign-ins shows no second factor was presented for any user.

What should the team do?

- ☐ A Recreate the Identity Center instance in the users' home Region
- ☐ B Enable MFA on each permission set as well
- ☐ C Switch the identity source to the Identity Center directory
- ☐ D Enforce MFA in Okta, because authentication is delegated to the external IdP

◆ PAUSE AND DECIDE

What should the team do?

A Recreate in another Region

The instance Region affects where it runs, not whether MFA is challenged. Users were signing in successfully.

C Switch to the Identity Center directory

Would make Identity Center's MFA apply, and it abandons Okta as the identity source - a large change to fix a setting in the wrong place.

B Enable MFA on permission sets

Permission sets define permissions and session duration. Authentication has already finished before a permission set is involved.

D Enforce MFA in Okta

Correct. Identity Center's own MFA applies only with its own directory, Managed Microsoft AD or AD Connector. With an external SAML IdP, that provider authenticates.

DOMAIN 4

Whoever authenticates the user is who enforces the second factor.

A CI/CD role holds `iam:PassRole` with Resource set to `*`. A reviewer states this is equivalent to granting the role the ability to become any role in the account.

The pipeline legitimately needs to pass two execution roles to Lambda, and one task role to ECS.

What should replace it?

- ☐ A `iam:PassRole` scoped to the three role ARNs, with a condition on `iam:PassedToService`
- ☐ B `iam:PassRole` with a condition requiring `aws:ResourceTag/Purpose` to equal workload
- ☐ C A permissions boundary on the CI/CD role listing the three roles
- ☐ D An SCP denying `iam:PassRole` except from the pipeline account

◆ PAUSE AND DECIDE

What should replace it?

- A

 Scope to three ARNs plus iam:PassedToService
Correct. The ARNs bound which roles may be passed; PassedToService bounds where, so a Lambda execution role cannot be passed to EC2.
- B

 A condition on aws:ResourceTag
A documented ABAC gap – you cannot restrict iam:PassRole using tags on the role. The condition never matches, and it never errors either.
- C

 A permissions boundary listing the roles
A boundary caps what the CI/CD role itself may do. It does not enumerate which roles may be passed onward.
- D

 An SCP restricting the account
Controls which account may call PassRole, not which roles may be passed. The over-broad grant inside the account is unchanged.

DOMAIN 4

PassRole cannot be restricted by tags. Enumerate the ARNs and add PassedToService.

A multi-tenant platform encrypts all tenant data under one KMS key, with tenant identifiers in the encryption context. A migration job needs decrypt access to one tenant's data for about eight hours, then no access at all.

No key policy or IAM policy may be modified.

What should the platform use?

- ☐ A A session policy limiting kms:Decrypt to that tenant's encryption context
- ☐ B A grant for Decrypt with an EncryptionContextSubset constraint, retired when the job completes
- ☐ C A second KMS key for that tenant, with the data re-encrypted under it
- ☐ D A temporary key policy statement, removed after eight hours

◆ PAUSE AND DECIDE

What should the platform use?

- A

A session policy on the encryption context

A session policy can only narrow permissions the role already holds. If the role cannot decrypt at all, no session policy grants it.
- B

A grant with EncryptionContextSubset, then retire

Correct. Scoped to one tenant by constraint, temporary by retirement, and created by API without touching a policy - the three properties that define a grant.
- C

A second key and re-encryption

Solves it by rebuilding the data model, at enormous cost, for an eight-hour job.
- D

A temporary key policy statement

Explicitly ruled out - the requirement says no key policy may be modified, and this is precisely what grants exist to avoid.

DOMAIN 5

Scoped, temporary, and no policy edit. Those three together always mean a grant.

A company creates a multi-Region KMS key in eu-west-1 with a tightly scoped key policy, then replicates it to us-east-1 and sa-east-1. Rotation is enabled on the primary.

An audit finds the sa-east-1 replica grants decrypt to a role that was never approved, added locally three months ago.

Which statement is correct?

- ☐ A Replica key policies are inherited; the audit finding is a console artefact
- ☐ B Rotation is per-replica, so policies diverged when the key rotated
- ☐ C Key material and rotation are shared; key policies, grants, aliases and tags are per-Region
- ☐ D Replicating a key permanently syncs its policy; re-replicate to restore it

◆ PAUSE AND DECIDE

Which statement is correct?

- A

 Policies are inherited
The opposite of how multi-Region keys work. Each replica has its own policy, and a local edit is a real change.
- B

 Rotation is per-replica
States the split backwards. Rotation is the shared property, controlled only on the primary; policies are the independent ones.
- C

 Material and rotation shared; policies and grants per-Region
Correct. Same key material, separate governance - which is the most examinable fact about multi-Region keys.
- D

 Replication permanently syncs the policy
A policy may be set at replication time; it is not kept in step afterwards, which is exactly how these diverged.

DOMAIN 5

Same material, separate governance. Controlling who may edit a replica's policy is an SCP or RCP problem, not a KMS feature.

An archival application has used SSE-C successfully for years. In June 2026 the team provisions a new S3 bucket, and every upload fails with HTTP 403 AccessDenied. The IAM role is unchanged, the bucket policy is permissive, and the same code still works against buckets created in 2024.

The application's regulator requires the company to hold the encryption keys itself.

What should the team do?

- ☐ A Set BlockedEncryptionTypes to NONE on the new bucket via PutBucketEncryption
- ☐ B Add s3:PutObjectAcl to the role's policy
- ☐ C Migrate the archive to SSE-KMS with an imported key
- ☐ D Enable S3 Bucket Keys, which SSE-C now requires

◆ PAUSE AND DECIDE

What should the team do?

- A

 Set BlockedEncryptionTypes to NONE
Correct. Since 6 April 2026 new general purpose buckets block SSE-C by default. A workload that genuinely needs it must unblock it deliberately.
- B

 Add s3:PutObjectAcl
A permissions-shaped guess. The identical role works against the older bucket, so the difference is the bucket, not the policy.
- C

 Migrate to SSE-KMS
AWS's general recommendation, and the regulator requires the company to hold the keys, which SSE-KMS does not satisfy.
- D

 Enable Bucket Keys
Bucket Keys reduce KMS request costs and have nothing to do with SSE-C, which involves no KMS key at all.

DOMAIN 5

Works on a 2024 bucket, fails on a 2026 one, same code and role. That is a default that changed between the two dates.

A support team of 80 engineers queries application logs in CloudWatch Logs. The logs contain customer email addresses and phone numbers. Compliance requires support engineers never see those values, while a five-person incident response team must be able to.

One mechanism must cover the console, Logs Insights, and the subscription filter feeding the SIEM.

What should be implemented?

- ☐ A Separate log groups for sensitive events, with different IAM policies
- ☐ B A Lambda subscription filter that strips PII before the SIEM
- ☐ C A data protection policy masking those identifiers, granting logs:Unmask only to the IR team
- ☐ D A Macie job identifying PII in the log data and alerting compliance

◆ PAUSE AND DECIDE

What should be implemented?

- A

 Separate log groups by sensitivity
Requires the application to know which events are sensitive before writing them, which is the assumption that already failed.
- B

 Lambda stripping PII before the SIEM
Covers one of the three egress points named. Engineers using the console or Insights would still see everything.
- C

 Data protection policy, logs:Unmask for the IR team only
Correct. Masking applies at every egress point – console, Insights and subscription filters – and logs:Unmask is exactly the two-tier access described.
- D

 A Macie job
Macie discovers sensitive data in S3, and reports rather than redacts. It would tell compliance what is there without hiding it from 80 engineers.

DOMAIN 5

'One mechanism covering three egress points' is a documented property of CloudWatch Logs data protection.

An organisation blocks public sharing of EBS snapshots with an SCP denying the relevant API actions. Twice, AWS has introduced a new sharing mechanism and the SCP silently stopped covering it until someone noticed months later.

The organisation wants the configuration itself enforced, so that new features arrive already governed.

What should the organisation use?

- ☐ A An SCP using NotAction to deny everything except permitted actions
- ☐ B A declarative policy for EBS, enforcing the configuration at the service level
- ☐ C A Config rule with automatic remediation for public snapshots
- ☐ D An RCP denying public sharing organisation-wide

◆ PAUSE AND DECIDE

What should the organisation use?

- A

 An SCP using NotAction
Would cover new actions and denies everything else in EC2 too. An enormous blast radius for a narrow problem.
- B

 A declarative policy for EBS
Correct. Declarative policies enforce a configuration at the service level and are maintained when the service adds features or APIs – the stated requirement.
- C

 Config rule with remediation
Detective and corrective. The snapshot is public during the window before remediation runs.
- D

 An RCP denying public sharing
The sharpest distractor – RCPs are newer and organisation-wide. They are still action-based, so they inherit the same problem of being outgrown.

DOMAIN 6

An SCP denies actions you named. A declarative policy declares a configuration, and survives the actions AWS invents next year.

A security team deploys a break-glass IAM role to every account using a service-managed StackSet targeting the organisation root, with automatic deployment enabled. The StackSet reports success in all 180 member accounts, with no failures and no drift.

During an organisation-level incident, responders find the role does not exist in the management account.

Why?

- ☐ A An SCP on the root prevented role creation in the management account
- ☐ B Automatic deployment must be disabled for the management account to be included
- ☐ C The management account must be moved into a targeted OU
- ☐ D CloudFormation does not deploy stacks to the management account, even within a targeted OU

◆ PAUSE AND DECIDE

Why?

- A

An SCP prevented it

Self-contradicting. SCPs have no effect in the management account. And a blocked creation would produce a failure, not silence.
- B

Disable automatic deployment

Automatic deployment governs whether accounts joining an OU get the stack. It has no bearing on the management account exclusion.
- C

Move it into a targeted OU

Placement does not change the exclusion. CloudFormation skips the management account wherever it sits.
- D

CloudFormation does not deploy to the management account

Correct, and AWS documents it. The account was never a target, which is why there is no failure and no drift to see.

DOMAIN 6

'No failures and no drift' is the tell. Nothing went wrong – the account was simply never in scope.

Scoring practice exam 1

- ◆ **15 of 20 is a pass** at this exam's ratio. Consistently 16 or better is where you want to be before booking.
- ◆ **Answer key: B D A C A D C B D A C B D A B C A C B D.**
- ◆ Score by domain, not just total. Three wrong in one domain matters more than five spread evenly.
- ◆ **Domains here:** Q1-3 detection, Q4-6 incident response, Q7-10 infrastructure, Q11-14 identity, Q15-18 data protection, Q19-20 governance.
- ◆ For anything you got wrong, go back to the module rather than re-reading the answer. The answer teaches the fact; the module teaches the discriminator.

ON THE EXAM

Next: practice exam 2, with the same weighting and a different set of traps.